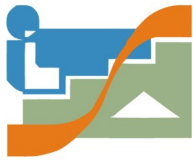


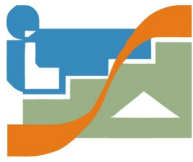
UNITAT 04

Implementació de mesures de ciberseguretat davant d'un IC

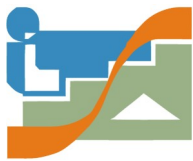




- **Desenvolupar procediments**
- **Preparar respostes ciber-resilients**
- **Establir fluxe de presa de decisions**
- **Tasques de restabliment de serveis afectats**
- **Documentació d'accions realitzades**



- **Desenvolupar procediments**
- Preparar respostes ciber-resilients
- Establir fluxe de presa de decisions
- Tasques de restabliment de serveis afectats
- Documentació d'accions realitzades



- **Desenvolupar procediments d'actuació detallats per donar resposta, mitigar, eliminar o contenir els tipus d'incidents de ciberseguretat més habituals**

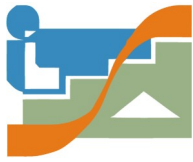
<https://www.muycomputer.com/2021/12/29/ciberseguridad-en-2021/>

<https://www.muycomputer.com/2020/12/30/ciberseguridad-en-2020/>

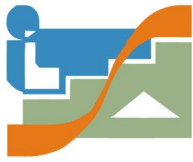
<https://www.muycomputer.com/2019/12/29/13-peores-incidentes-seguridad-2019/>

- **Enginyeria social**
- **Fugida d'informació**
- **Ransomware**
- **Phishing i defacement de pàgines web**
- **Formar part d'una Botnet que realitza atacs**

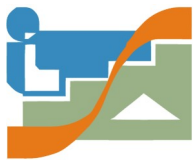




- **Enginyeria social**
 - **medidas-seguridad-correo-electronico**
 - **kit-concienciacion**
- **Fugida d'informació**
 - **guia-fuga-informacion**
 - **Polítiques d'accés a la informació**
 - **Campanyes conscienciació**
 - **ILM**
 - **DLP**
- **Ransomware**
 - **que-no-te-secuestren-el-ordenador**
 -
- **Phishing i defacement de pàgines web**
 - **prevenir-phishing**
- **Formar part d'una Botnet que realitza atacs**
 - **proteger-tu-empresa-del-malware**



- Desenvolupar procediments
- Preparar respostes ciber-resilients
- Establir fluxe de presa de decisions
- Tasques de restabliment de serveis afectats
- Documentació d'accions realitzades



Ciberresiliència: Capacitat de les organitzacions o sistemes de recuperar-se ràpidament d'atacs deliberats o incidents que impliquen l'ús de les tecnologies de la informació i la comunicació.

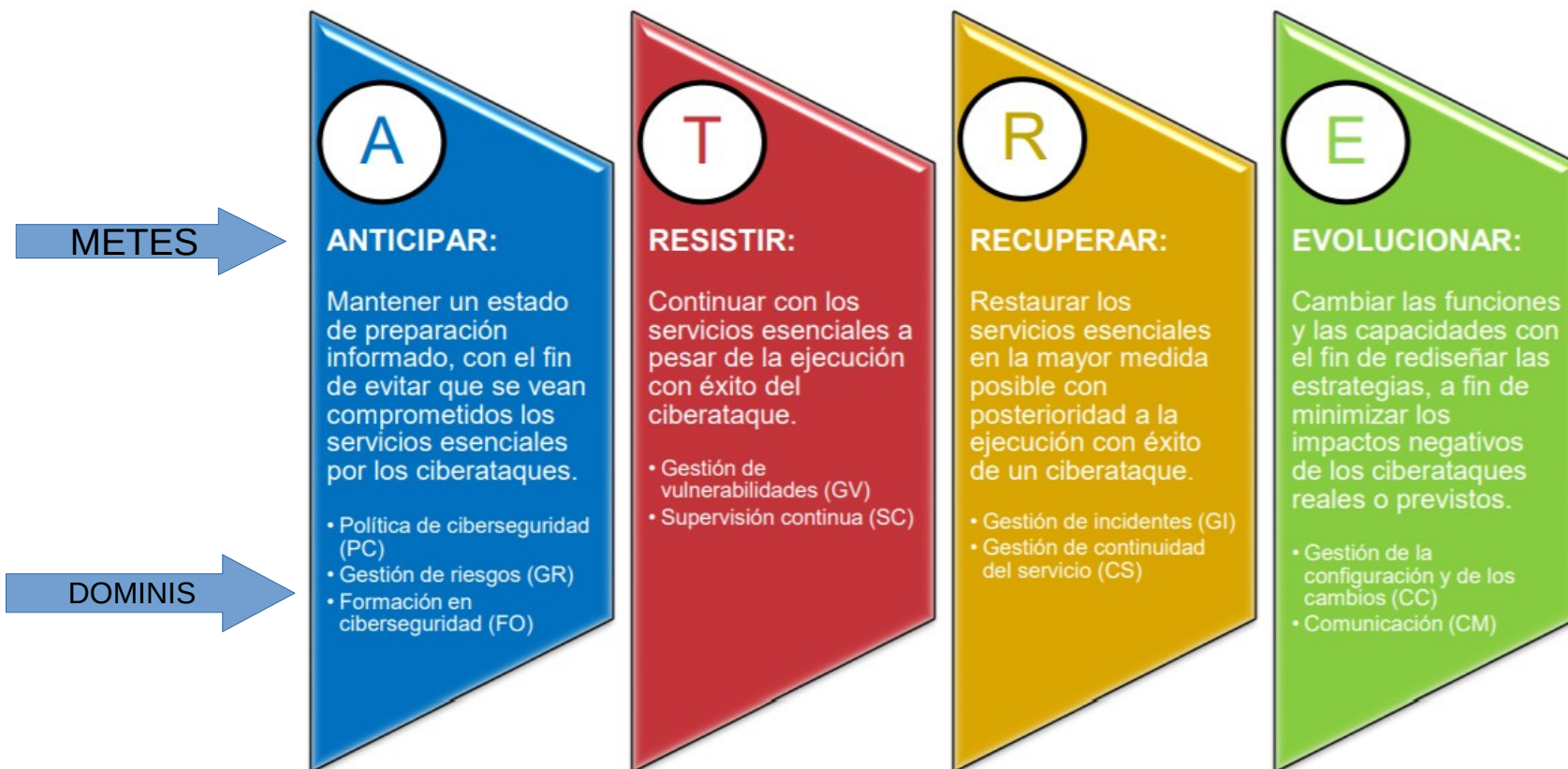
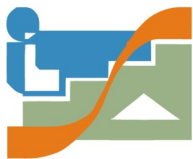
Preparar respostes ciber-resilients

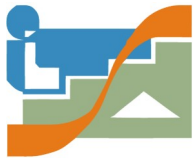
<https://www.incibe-cert.es/blog/anticipar-las-cuatro-metas-ciberresiliencia>

- Anticipar
- Resistir
- Recuperar
- Evolucionar

Model IMC **imc-indicadores-mejora-ciberresiliencia** -> tres documents

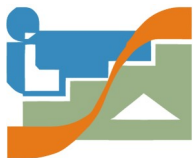
- Metodologia Avaluació
- Diccionari Indicadors
- Formulari Ciberresiliència





Dominis funcionals

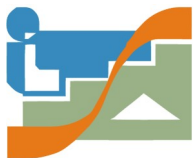
- Política de Ciberseguretat (PC)
- Gestió de Riscos (GR)
- Formació en Ciberseguretat (FO)
- **Gestió de Vulnerabilitats (GV)**
- **Supervisió Contínua (SC)**
- **Gestió d'incidents(GI)**
- **Gestió de Continuïtat del Servei (CS)**
- **Gestió de la Configuració i dels Canvis (CC)**
- **Comunicació (CM)**



Etapas de la metodologia

- Delimitar l'abast de l'anàlisi.
- Realitzar una autoavaluació.
- Aplicar una sèrie de mesures correctives dins de l'abast.
- Repetir l'autoavaluació per a analitzar l'efectivitat de les mesures.

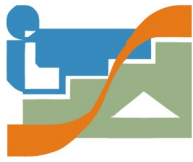




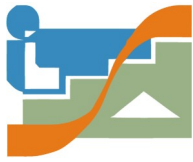
Ciberresiliència

INCIBE adopta dels estàndards els següents nivells de maduresa





- Desenvolupar procediments
- Preparar respostes ciber-resilients
- **Establir fluxe de presa de decisions**
- Tasques de restabliment de serveis afectats
- Documentació d'accions realitzades



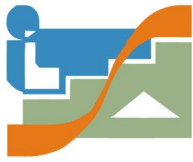
Establir fluxe de presa de decisions

L'estratègia de contenció varia segons la mena d'incident i els criteris han d'estar ben documentats per a facilitar la ràpida i eficaç presa de decisions. Alguns criteris que poden ser presos com a base són:

- Criteris Forenses.
- Mal potencial i furt d'actius.
- Necessitats per a la preservació d'evidència.
- Disponibilitat del servei.
- Temps i recursos per a implementar l'estratègia.
- Efectivitat de l'estratègia per a contindre l'incident (parcial o total).
- Duració de la solució.

<https://www.incibe.es/protege-tu-empresa/blog/plan-de-crisis>

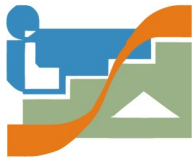
[plan_de_contingencia_y_continuidad_de_negocio.pdf](#)



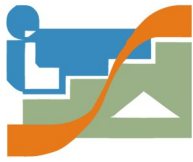
Establir fluxe de presa de decisions

Pla de contingència » Pla de crisis

- **Ha de ser Pràctic, Operatiu , Real**
 - Evitar incloure informació extra no relevant per a la gestió de la crisis
 -
- **Ha de contindre**
 - **Informació d'àmbit general**
 - Sistemes i elements crítics
 - Personal implicat en situacions de crisis
 - Procés d'escalat
 - Informació d'emergència
 - Passos a seguir
 - Escenaris de desastre
 -
- **Com posar-lo en pràctica**
 - Detectar la incidència
 - Escalar i notificar adequadament
 - Analitzar escenaris i escollir el que aplique
 - Pla de recuperació (tècnics)



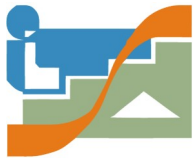
- Desenvolupar procediments
- Preparar respostes ciber-resilients
- Establir fluxe de presa de decisions
- Tasques de restabliment de serveis afectats
- Documentació d'accions realitzades



Tasques de restabliment de serveis afectats

La finalitat de la fase de recuperació consisteix a retornar el nivell d'operació al seu estat normal i que les àrees de negoci afectades puguen reprendre la seua activitat. És important **no precipitar-se** en la posada en producció de sistemes que s'han vist implicats en ciberincidents.

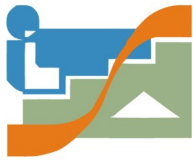
Convé prestar especial atenció a aquests sistemes durant la posada en producció i buscar qualsevol signe d'activitat sospitosa, **definint un període de temps** amb mesures addicionals de monitoratge.



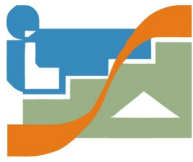
Tasques de restabliment de serveis afectats

tienes-plan-recuperacion-desastres?

- Desenvolupar les mesures per a recuperació
- Realitzar proves
- Actualitzar i millorar el pla
- Capacitar als encarregats de posar-lo en marxa,
- Conscienciar i difondre el pla



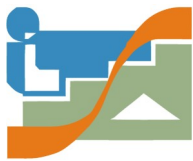
- Desenvolupar procediments
- Preparar respostes ciber-resilients
- Establir fluxe de presa de decisions
- Tasques de restabliment de serveis afectats
- Documentació d'accions realitzades



Documentació d'accions realitzades

- Descripció de l'incident
- Determinació de possibles causes
- Valoració de dany i costos (impacte a la organització)
- Proposta mesures de millora

[respuesta-incidentes-he-restaurado-los-sistemas-y-ahora](#)



Documentació d'accions realitzades

Documentar tot el succeït ens servirà per a comprendre l'incident i avaluar les accions preses. Amb això podem aprendre dels nostres errors i reforçar les bones pràctiques per si torna a ocórrer i per a intentar evitar-ho en el futur. En la documentació haurà de constar:

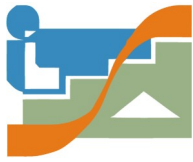
Descripció de l'incident.

- Quina data i hora es va identificar l'incident.
- Tipologia de l'incident: ransomware, fugida d'informació, denegació de servei, etc.
- Recursos afectats, amb quina gravetat i com va afectar l'empresa.
- Registra si va ser necessari detindre serveis, avisar a clients o proveïdors, etc.
- Quines accions es van prendre per a solucionar-ho, quan es van dur a terme i per què es va fer així.
- Evidències recollides durant tot el procés, per exemple correus rebuts, o fitxers o unitats de disc xifrats.

Possible origen. Indicar quin ha pogut ser l'origen de l'incident sobre la base de tots els passos dels dos articles anteriors. També es registrarà si ja ha sigut resolt.

Personal involucrat. Totes les persones que han participat d'una manera o un altre en la resolució de l'incident han d'estar identificades convenientment.

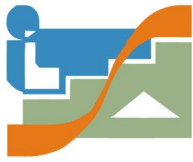
Data i hora de resolució de l'incident. S'ha de portar un registre seqüencial d'actuacions.



Documentació d'accions realitzades

Valorar els danys i costos de l'incident

- Reposició d'equips o el seu programari
- Els danys reputacionals deguts, per exemple, a la divulgació d'informació confidencial
- Legals
- Els associats a la recuperació de l'activitat normal i anàlisi de l'incident
- Els deguts al temps d'inactivitat o lucre cessant.



Documentació d'accions realitzades

Revisar les polítiques de l'empresa: lliçons apreses

- Què ha fallat perquè es produïra l'incident?
- Quina política de seguretat no ha funcionat?
- Què cal millorar perquè no torne a succeir?
- He informat els empleats del que ha ocorregut?
- És necessari formar als empleats perquè sàpien com actuar en aquests casos?
- La gestió de l'incident va ser correcta?
- Quins passos es poden millorar per a fer la gestió de l'incident més fluida?
- En cas d'haver de fer l'incident públic, la comunicació amb els mitjans va ser correcta i fluida?
- Es va realitzar un exercici de transparència amb l'opinió pública o per contra les comunicacions van ser opaques?
- Si l'incident va afectar informació privada de clients o proveïdors, es va realitzar la comunicació dins del termini i en la forma escaient?